

HW03 Consolidated Bug and Usability-Finding Report

Student: Đặng Đăng Khoa **Student ID:** 23127207 **System under test:** EShop **Report date/timezone:** 2026-08-02 — Asia/Bangkok (UTC+7) **Review state:** HUMAN_REVIEWED

1. Scope and classification rules

This is the single defect/finding register for all three tasks. It deliberately preserves three different units of analysis:

- A **failed checklist assertion** is one Expected-versus-Actual mismatch in Task 1. Several failed assertions may share one product root cause.
- A **software bug** is reproducible product behavior that contradicts a requirement, security baseline or stable product expectation.
- A **usability issue** is observed user difficulty, error recovery, hesitation or wrong turn. It is not automatically a software defect.
- A **cross-platform finding** reports the recurrence of an existing root cause across environments; it is not counted as a new bug merely because it reproduced in another browser.

Severities are ordered Critical / S1, High / S2, Medium / S3, then Low / S4. Task 2 retains its S1–S4 usability scale. The two scales are shown together only to establish review order; they are not claimed to be mathematically identical.

No single grand-total bug count is asserted because Task 1 counts failed assertions, Task 2 counts root-cause bugs and user-impact findings, and Task 3 measures environment frequency. The traceable facts are:

Dataset	Traceable count	Publication state
Task 1 failed checklist assertions	20	All 20 rows have verified GitHub URLs across 18 unique issues.
Task 2 software bugs	3	All map to existing issues: #55, #37 and #118.
Task 2 usability issues	4	Kept separate from software bugs and participant frequencies.
Task 3 systemic finding groups	9	Local report only; no new publication is claimed.

2. Task 1 — failed GUI assertions

The table below is the complete Task 1 fail set: 1 Critical, 5 High, 12 Medium and 2 Low. Every row links to its original screenshot and a verified GitHub issue.

Ra nk	Checklist ID	Sev erit y	Expected	Observed actual	Mode	Git Hu b	Evid ence
1	GUI-WEB-LOGIN-003	Criti cal	Password characters are masked using type=password .	Password input is type=text .	LIVE_LOCAL _SUT	#37	PNG
2	GUI-WEB-LOGIN-010	Hig h	Third consecutive wrong login locks for 30 seconds and the UI presents an appropriate locked state.	Requests returned 401/401/403, while the UI continued to show only the generic login-failed message.	LIVE_LOCAL _SUT	#23 8	PNG
3	GUI-WEB-REGISTER-006	Hig h	Duplicate email registration is rejected with a deterministic backend validation message.	A second registration for the same email returned HTTP 200 and navigated as success.	LIVE_LOCAL _SUT	#11 7	PNG

Ra nk	Checklist ID	Sev erity	Expected	Observed actual	Mode	Git Hu b	Evid ence
4	GUI-ADMIN-CATEGORY-004	Hig h	required prevents an empty category-name submission.	required=null ; an empty POST with {"name":""} was observed.	MOCKED_WRITE_PREVENTION	#291	PNG
5	GUI-ADMIN-CATEGORY-006	Hig h	Delete opens an explicit confirmation dialog.	No delete-confirmation dialog was observed.	LIVE_LOCAL_SUT	#292	PNG
6	GUI-ADMIN-CATEGORY-008	Hig h	A category referenced by a product cannot be deleted and an error is shown.	The referenced synthetic category was removed; no error appeared.	LIVE_LOCAL_SUT	#293	PNG
7	GUI-WEB-LOGIN-001	Med ium	Main login heading is Đăng Nhập .	Heading is Đăng Ký .	LIVE_LOCAL_SUT	#199	PNG
8	GUI-WEB-LOGIN-002	Med ium	Field is labelled Email and uses type=email .	First label is Username ; input uses type=text .	LIVE_LOCAL_SUT	#203	PNG
9	GUI-WEB-LOGIN-009	Med ium	Submit label is Vietnamese Đăng nhập with natural/default tab order.	Submit text is Sign In .	LIVE_LOCAL_SUT	#198	PNG
10	GUI-WEB-LOGIN-011	Med ium	Tab moves naturally through fields and controls with visible focus.	Positive-tabindex Sign In precedes the form inputs in the recorded focus sequence.	LIVE_LOCAL_SUT	#201	PNG
11	GUI-ADMIN-LOGIN-002	Med ium	Each admin-login input has an associated <label> .	The form contains zero label elements for two inputs.	LIVE_LOCAL_SUT	#45	PNG
12	GUI-ADMIN-LOGIN-003	Med ium	Invalid admin password produces an accessible inline error banner.	A native Đăng nhập thất bại dialog appeared; inline feedback count was zero.	LIVE_LOCAL_SUT	#46	PNG
13	GUI-ADMIN-LOGIN-004	Med ium	A non-admin account receives clear inline authorization feedback.	A native Bạn không phải là admin! dialog appeared; inline feedback count was zero.	LIVE_LOCAL_SUT	#46	PNG
14	GUI-ADMIN-CATEGORY-010	Med ium	A spinner or skeleton is visible while categories load.	No loading indicator appeared during a controlled 2.5-second API delay.	MOCKED_SLOW_API	#295	PNG
15	GUI-ADMIN-CATEGORY-013	Med ium	Submit is disabled while a category write is pending.	A rapid double click produced two POST requests; the button did not provide pending-state protection.	MOCKED_SLOW_WRITE	#296	PNG
16	GUI-MOBILE-LOGIN-002	Med ium	Mobile login field is visibly labelled Email .	Username is visible and there is no standalone Email label.	LIVE_LOCAL_SUT	#297	PNG
17	GUI-MOBILE-LOGIN-004	Med ium	Mobile submit label is Vietnamese Đăng nhập .	Rendered label is Sign In .	LIVE_LOCAL_SUT	#297	PNG
18	GUI-MOBILE-LOGIN-010	Med ium	Touch target is at least 44×44 CSS px/dp under the checklist threshold.	Recorded bounding box was 342×39 CSS px.	LIVE_LOCAL_SUT	#298	PNG
19	GUI-WEB-LOGIN-007	Low	Forgot-password transition preserves SPA navigation/state.	/forgot-password loaded by full-document navigation and the SPA marker was lost.	LIVE_LOCAL_SUT	#230	PNG

Rank	Checklist ID	Severity	Expected	Observed actual	Mode	GitHub	Evidence
20	GUI-ADMIN-CATEGORY-009	Low	An explicit empty-state message or illustration is shown.	A controlled empty response rendered zero rows and zero empty-state messages.	MOCKED_EMPTY_API_STATE	#294	PNG

Task 1 publication and deduplication boundary

A live duplicate search inspected all 262 issues available before publication through the repository API on 2026-08-02. `GUI-ADMIN-LOGIN-002` matches [#45](#), which explicitly covers missing labels on the Web Admin login. `GUI-ADMIN-LOGIN-003` and `GUI-ADMIN-LOGIN-004` share the same `frontend-admin handleLogin` native-alert root cause and map to [#46](#). Near matches were rejected when their body referred to another implementation—for example, [#35/#36/#198](#) cover the Web `/login`, not `frontend-mobile/App.js`, and [#255](#) covers deleting an Admin product, not a category.

The GitHub App write path initially returned HTTP 403. After the user authorized Git Credential Manager device authentication, a branch containing only the seven approved Task 1 PNGs was pushed. Eight deduplicated root-cause issues [#291–#298](#) were created. All seven raw image endpoints returned HTTP 200 with `image/png`, and all eight issue bodies were read back with one embedded image each. No Task 2 participant evidence was uploaded.

2.1 Empty category name can be submitted

- Proposed title: `[BUG][Admin Category] Empty category name can be submitted`.
- Checklist: `GUI-ADMIN-CATEGORY-004`; FR-14; High/P1.
- Source location: `frontend-admin/src/App.jsx:142` and `frontend-admin/src/App.jsx:297` — submit sends `categoryName`; the input has no required-state guard.
- Reproduction: log in to Web Admin → open Categories → leave the name empty → choose `Thêm mới` → inspect the request.
- Expected: submission is blocked and a clear validation message is shown.
- Actual: `required=null`; an empty POST with `{"name":""}` was emitted.
- Evidence: [026-admin-category-empty.png](#).
- Publication: [issue #291](#), verified open with the evidence image embedded.

2.2 Category deletion has no confirmation

- Proposed title: `[BUG][Admin Category] Category is deleted without a confirmation dialog`.
- Checklist: `GUI-ADMIN-CATEGORY-006`; FR-14 / destructive-action heuristic; High/P1.
- Source location: `frontend-admin/src/App.jsx:153` and `frontend-admin/src/App.jsx:323` — the delete button calls `deleteCategory` directly.
- Reproduction: log in → open Categories → select an existing category → choose `Xóa`.
- Expected: a confirmation dialog allows Cancel or explicit confirmation before deletion.
- Actual: no confirmation dialog was observed and the delete request proceeded immediately.
- Evidence: [027-admin-category-delete.png](#).
- Publication: [issue #292](#), verified open with the evidence image embedded.

2.3 Referenced category can be deleted

- Proposed title: `[BUG][Admin Category] Category referenced by a product can be deleted`.
- Checklist: `GUI-ADMIN-CATEGORY-008`; FR-14 / data integrity; High/P1.
- Source location: `frontend-admin/src/App.jsx:153`; the client issues DELETE without a reference precheck, and the backend accepted the operation.

- Reproduction: create a synthetic category → create a synthetic product using it → delete the category → refresh product/category data.
- Expected: the server rejects deletion, the category remains and the UI displays the conflict.
- Actual: the referenced category no longer remained, no error dialog appeared and backend deletion succeeded.
- Evidence: [028-admin-category-delete-in-use.png](#).
- Publication: [issue #293](#), verified open with the evidence image embedded.

2.4 Categories table has no empty state

- Proposed title: `[BUG][Admin Category] Empty category list renders a blank table body`.
- Checklist: `GUI-ADMIN-CATEGORY-009`; IA-04 / FR-24 state heuristic; Low/P3.
- Source location: `frontend-admin/src/App.jsx:317`; the body only maps `categories` and has no zero-length branch.
- Reproduction: return an empty array from `GET /api/categories` → open Categories.
- Expected: a friendly `Chưa có danh mục nào` message or illustration is visible.
- Actual: zero rows and zero empty-state messages were rendered.
- Evidence: [029-admin-category-empty-state.png](#).
- Publication: [issue #294](#), verified open with the evidence image embedded.

2.5 Categories fetch has no loading state

- Proposed title: `[BUG][Admin Category] No loading indicator while categories are fetched`.
- Checklist: `GUI-ADMIN-CATEGORY-010`; IA-04 feedback/state; Medium/P2.
- Source location: `frontend-admin/src/App.jsx:41`; `fetchData` has no categories-loading state, and the Categories view has no spinner/skeleton branch.
- Reproduction: delay the categories response by 2.5 seconds → open the Categories tab during the pending request.
- Expected: a spinner, skeleton or explicit loading message is visible.
- Actual: loading-indicator count remained zero for the controlled delay.
- Evidence: [030-admin-category-loading.png](#).
- Publication: [issue #295](#), verified open with the evidence image embedded.

2.6 Category form permits duplicate submissions

- Proposed title: `[BUG][Admin Category] Rapid double click sends duplicate create requests`.
- Checklist: `GUI-ADMIN-CATEGORY-013`; IA-04 resilience; Medium/P2.
- Source location: `frontend-admin/src/App.jsx:142` and `frontend-admin/src/App.jsx:305`; no pending-write state disables the submit button.
- Reproduction: delay `POST /api/categories` → enter a unique category name → double-click `Thêm mới` rapidly.
- Expected: the first click disables the button until the request resolves and only one POST is sent.
- Actual: two POST requests were observed; pending-state protection was absent.
- Evidence: [033-admin-category-double-submit.png](#).
- Publication: [issue #296](#), verified open with the evidence image embedded.

2.7 Mobile login uses Web-English labels

- Proposed title: `[BUG][Mobile Login] Username and Sign In labels violate Vietnamese localization`.
- Checklist: `GUI-MOBILE-LOGIN-002`, `GUI-MOBILE-LOGIN-004`; FR-21; Medium/P2.
- Source location: `frontend-mobile/App.js:759` — the mobile implementation independently renders `Username` and `Sign In`; this is not the Web `Login.jsx` defect tracked by `#35/#36/#198`.

- Reproduction: launch the Mobile app/Expo screen → open Login → inspect the identifier label and primary submit label.
- Expected: Email and Đăng nhập.
- Actual: Username and Sign In.
- Evidence: 034-mobile-login-baseline.png.
- Publication: issue #297, verified open with the evidence image embedded; it covers both localization checklist rows.

2.8 Mobile login touch target is below 44 px

- Proposed title: [BUG][Mobile Login][Accessibility] Sign In touch target height is only 39 px.
- Checklist: GUI-MOBILE-LOGIN-010 ; accessibility heuristic; Medium/P2.
- Source location: frontend-mobile/App.js:782 and frontend-mobile/App.js:1052 ; the button uses 10 px padding without a 44 px minimum height.
- Reproduction: render the Mobile login screen at the recorded 390 px viewport → measure the primary button bounding box.
- Expected: a touch target at least 44×44 CSS px/dp under the checklist threshold.
- Actual: the recorded bounding box was 342×39 CSS px.
- Evidence: 034-mobile-login-baseline.png.
- Publication: issue #298, verified open with the evidence image embedded.

3. Task 2 — software bugs

3.1 Severity-ranked summary

Rank	Bug ID	Severity	Participant attribution	Frequency	Independent reproduction	Canonical issue
1	BUG-PF-02 — valid leading-zero phone rejected	S1	P01, P02, P04	3/7	Reproduced 2026-07-31 using synthetic data	#55
2	BUG-AUTH-PLAINTEXT-01 — login password shown as plaintext	S2	P01, P02, P04, P05, P07	5/7	Reproduced 2026-07-31 using synthetic data	#37
3	BUG-REG-PASSWORD-POLICY-01 — server bypasses required special-character policy	S2 provisional	NONE — TECHNICAL_ONLY	N/A	Reproduced 2026-08-02 by direct API with synthetic data	#118

3.2 BUG-PF-02 — profile phone validation contradicts FR-04

FR-04 requires a phone value beginning with 0 and containing 10–11 digits. P01, P02 and P04 each attempted requirement-conforming leading-zero formats and received the phone-invalid path. P04 later received success with a non-leading-zero value, which contradicts the stated rule. This blocked SC3 for all three at confirmed task end.

- Participant evidence: P01/D01 00:00:53–00:01:49; P02/D02 00:00:57–00:01:34; P04/D04 00:01:43–00:02:09.
- Expected: accept valid 10- and 11-digit leading-zero values, reject non-leading-zero values, then persist the update.
- Actual: valid formats were rejected; a contrary format could be accepted.
- Evidence: safe reproduction image, machine-readable finding register and the P01/P02/P04 session reports.
- Recommended retest: automated boundary coverage plus five users; both valid lengths persist, invalid leading digit is rejected, and 5/5 complete after at most one recovery.

3.3 BUG-AUTH-PLAINTEXT-01 — password control exposes credential characters

The login password control renders characters as ordinary text. It was visible in five official participant sessions: P01, P02, P04, P05 and P07. P03 and replacement P06 did not reach the relevant login evidence, so they are not counted.

- Expected: password masked by default, with any reveal action explicit and reversible.
- Actual: characters rendered as plaintext, creating direct shoulder-surfing and recording exposure.
- Evidence: P01/D01 00:00:19–00:00:33; P02/D02 00:00:17–00:00:35; P04/D04 00:01:01–00:01:39; P05/D05 00:00:39–00:00:46; P07/D07 00:00:29–00:00:48; [safe reproduction image](#).
- Recommended retest: password is masked by default in every supported browser; reveal/remask works; default screenshots and recordings expose no characters.

3.4 BUG-REG-PASSWORD-POLICY-01 — backend accepts a password missing the required special class

FR-01 requires a special character from @ \$! % * ? & in addition to the other required character classes. A supplemental direct-API test created an account using a password with no allowed special character and then logged in successfully. The frontend passed all 13 EP/BVA regex cases, so the reproduced defect is server-side enforcement, not the frontend allowed-character set.

- Attribution: **NONE**; this technical reproduction is not assigned to P04, P06 or any participant.
- Frequency: **N/A**; it is excluded from all P01–P07 rates.
- Expected: missing-class and length-7 requests return a deterministic 4xx and create no usable account; valid length-8 cases and each allowed special character are accepted.
- Actual: direct registration returned 200 and the resulting account logged in with 200.
- Evidence: [safe reproduction image](#), [safe JSON result](#) and [canonical issue #118](#).
- Duplicate policy: #118 is the existing canonical defect. No duplicate issue was created, and this consolidated report does not claim that a new evidence comment was published.

4. Task 2 — usability issues, kept separate from bugs

Rank	Finding ID	Participants	Frequency	Severity	Observable impact	Relationship to software bugs
1	UF-PHONE-RECOVERY-01	P01, P02, P04	3/7	S1	Repeated edits/submits did not produce a specification-conforming route to SC3.	Shares evidence with BUG-PF-02 , but describes recovery quality rather than the validator defect.
2	UF-REG-PASSWORD-RECOVERY-01	P04, P06	2/7	S2	P04 needed one recovery; P06 made four failed submits and did not complete SC1.	Session video cannot reveal masked inputs; it does not prove BUG-REG-PASSWORD-POLICY-01 .
3	UF-LOGIN-IDENTIFIER-01	P07	1/7	S3	One failed login and about five seconds of hesitation before self-recovery to full email.	Copy/design issue; no separate software-bug claim.
4	UF-PASSWORD-MANAGER-DETOUR-01	P04	1/7	S4	Approximately two-second wrong turn into Edge Password Manager, followed by self-recovery.	Isolated integration observation; no GitHub bug claim.

No participant quote, moderator probe or self-reported interpretation is available. Recommendations are therefore grounded only in visible behavior:

- After fixing the phone validator, show a field-level example explaining “starts with 0, 10–11 digits,” retain other entered fields, and focus the invalid control.

- For registration, expose a live policy checklist without exposing the password value; aim for successful registration after at most one validation error in a five-user retest.
- Label the login identifier as `Email`, localize the action consistently, and avoid account-enumerating feedback.
- Review `autocomplete` semantics and supported-browser password-manager behavior without treating every system prompt as a participant wrong turn.

Full timestamps remain in the seven [coded session reports](#) and the [machine-readable finding register](#). Contradictory and non-finding interpretations are consolidated in this report rather than duplicated in a second findings report.

5. Task 3 — cross-platform recurrence

Task 3 executed the 58 checklist IDs in four environments. Every environment produced 37 Pass, 20 Fail and 1 Not Observable, so the following nine groups recurred in 4/4 executed environments. Chrome Windows and Firefox Windows are eligible platform evidence; WebKit on Windows is not Safari, and Pixel emulation is not a physical Android run.

Rank	Cross-platform root-cause group	Frequency	Severity	Related IDs
1	Plaintext password plus incorrect login semantics/localization	4/4	Critical	GUI-WEB-LOGIN-001/002/003/009
2	Delete lacks confirmation and permits deletion of an in-use category	4/4	High	GUI-ADMIN-CATEGORY-006/008
3	Locked HTTP state is not communicated by the UI	4/4	High	GUI-WEB-LOGIN-010
4	Duplicate email registration succeeds	4/4	High	GUI-WEB-REGISTER-006
5	Admin login lacks labels and uses native failure alerts	4/4	Medium	GUI-ADMIN-LOGIN-002/003/004
6	Category form lacks empty-name protection, empty/loading states and double-submit protection	4/4	Medium	GUI-ADMIN-CATEGORY-004/009/010/013
7	Positive tabindex places submit before inputs	4/4	Medium	GUI-WEB-LOGIN-011
8	Expo Web mobile login has inconsistent labels and a 39 px-high target	4/4 Expo Web runs	Medium	GUI-MOBILE-LOGIN-002/004/010
9	Forgot-password loses the SPA marker through full navigation	4/4	Low	GUI-WEB-LOGIN-007

No failure was demonstrated to be browser-exclusive. Minor focus-sequence details differed, but the failed expectation remained the same. `GUI-MOBILE-LOGIN-011` stayed Not Observable because desktop/headless Expo Web does not produce a real mobile soft keyboard. Platform-level status and screenshot traceability remain in the [cross-platform matrix](#) and [evidence index](#).

6. Evidence and reporting safeguards

- All participant references use only P01–P07. No raw name, email, phone, address or password is reproduced here.
- Synthetic values are used only for isolated reproduction and are never counted as participants.
- `NOT_OBSERVABLE`, `NONE`, `N/A` and missing evidence remain explicit; no Task 1 issue publication is pending.
- Existing GitHub URLs are reused only after duplicate search. Newly created issues are claimed only where GitHub returned and subsequently served the verified URL; no unpublished comments or platform runs are claimed.
- Mocked modes are labelled at the affected assertion; they support UI-state evaluation but are not disguised as production write evidence.
- Cross-platform recurrence does not multiply an application defect into four separate bugs.

The item-level source of truth remains the Task 1 checklist/results, Task 2 finding register/session coding and Task 3 results matrix linked from [Main_Report.md](#).